Autenticación de correo: SPF, DKIM y DMARC de punta a punta

> **Belona Cybersecurity** · octubre 2026 Caso real sobre dominio propio: `belonacyber.com`, con Google Workspace.
> *English version:* `english/email-authentication-EN.md`

El problema que resuelve

El correo electrónico se diseñó sin autenticación. El campo **"De:"** que ve el destinatario **es texto que el remitente escribe**, igual que el remitente de un sobre de papel: nadie en la oficina postal comprueba que sea verdad.

Por eso cualquiera puede mandar un correo que parezca venir de una empresa. Y para una oficina que maneja datos financieros —un preparador de impuestos, un contador, un abogado— eso no es una molestia: **es la vía de fraude más usada contra sus clientes y contra el IRS.**

Los tres controles cierran esa puerta, y cada uno responde una pregunta distinta:

	Pregunta que responde	Analogía
SPF	¿salió de un servidor autorizado?	la lista de carteros que pueden despachar a mi nombre
DKIM	¿es de quien dice y llegó íntegra?	el sello dentro de la carta
DMARC	¿qué hago si falla alguna?	la instrucción al cartero, más un informe

Los tres son necesarios y ninguno sustituye a otro. SPF no detecta modificación en tránsito; DKIM no dice de dónde salió; y sin DMARC, **los dos anteriores no se aplican**: el servidor que recibe no tiene instrucción de qué hacer cuando fallan.

El error más común: `p=none` sin `rua`

El registro DMARC más frecuente del mundo es este:

```
v=DMARC1; p=none
```

Y **no hace absolutamente nada.**

- `p=none` significa *"no bloquees nada"*
- sin `rua=`, tampoco recoge informes

Se supone que `p=none` es la fase de **observación**: todavía no bloqueas, pero **miras** quién manda correo a tu nombre. Sin dirección de informe, no observa. Es un registro que existe para que alguien pueda marcar una casilla.

Nunca se dice "no tienen DMARC" cuando el registro existe. Lo preciso es: *está puesto, pero en modo de observación y sin dirección de informe, así que ni siquiera observa.* Esa precisión es la diferencia entre sonar como alguien que leyó la configuración y alguien que corrió una herramienta en línea.

El despliegue, por etapas

El error que tumba el correo de una empresa es poner `p=reject` el primer día. Si hay un sistema legítimo que manda a nombre del dominio y nadie lo recordaba —una herramienta de facturación, un formulario, un servicio de envíos— sus correos empiezan a rebotar **y nadie se entera hasta que un cliente reclama**.

La secuencia correcta:

Etapa	Registro	Qué pasa	Cuánto
1 · Observar	`p=none; rua=...`	nada se bloquea; llegan informes diarios	2–4 semanas
2 · Cuarentena	`p=quarantine; rua=...`	lo que falla va a spam, no se pierde	4–8 semanas
3 · Rechazo	`p=reject; rua=...`	lo que falla no se entrega	permanente

Cada etapa es reversible y cada una necesita evidencia antes de la siguiente. No se avanza por calendario: se avanza cuando los informes muestran que todo lo legítimo pasa.

En este caso: `p=quarantine` activo desde octubre, con paso a `p=reject` previsto para diciembre, **después de un mes de informes limpios**.

Leer el primer informe

Los informes DMARC llegan en XML comprimido, uno por proveedor y por día. Este es el primero recibido, íntegro:

```
<policy_published>
  <domain>belonacyber.com</domain>
  <p>quarantine</p>
  <pct>100</pct>
</policy_published>
<record>
  <row>
    <source_ip>209.85.220.41</source_ip>
```

```
    <count>1</count>
    <policy_evaluated><dkim>pass</dkim><spf>pass</spf></policy_evaluated>
  </row>
  <auth_results>
    <dkim><domain>belonacyber.com</domain><result>pass</result>
          <selector>google</selector></dkim>
    <spf><domain>belonacyber.com</domain><result>pass</result></spf>
  </auth_results>
</record>
```

Qué dice, en orden de importancia:

1. **La política publicada es la que creías.** `p=quarantine` — el mundo la ve.
2. `source_ip` **209.85.220.41** resuelve a `mail-sor-f41.google.com`: el servidor propio. **Nadie más está mandando a nombre del dominio.**
3. **SPF y DKIM en** `pass`, con el selector `google` — eso **confirma que el DKIM está configurado y firma**, un dato que no se puede obtener desde fuera sin conocer el selector.
4. `disposition: none` — no se bloqueó nada porque no hizo falta.

El informe no sirve solo para detectar ataques. Sirve para saber qué puedes bloquear sin romper nada — que es lo que autoriza el paso a `p=reject`.

La trampa de la migración de DNS

Durante este trabajo el dominio se movió de registrador a otro proveedor de DNS. Es la operación donde más correos se pierden, y por una razón concreta:

El registro DKIM mide 408 caracteres. Un registro TXT no admite más de 255 por cadena, así que se parte internamente en dos. **Ahí es donde se trunca al copiar entre proveedores** — y el fallo no avisa:

- el correo **sigue saliendo**
- la firma deja de validar
- empieza a caer en spam
- y solo se descubre en el siguiente informe DMARC, con `dkim=fail`

Cómo se evitó

1. Capturar el estado anterior antes de tocar nada, como documento, con los nameservers originales para poder volver.

2. Verificar DNSSEC. Si está activo y se cambian los nameservers, el dominio **deja de resolver por completo** —correo incluido— porque las firmas no coinciden con lo que el registro `.com` tiene anotado. Comprobado: sin registro `DS`, seguro migrar.

3. Comparar el DKIM carácter por carácter, no a ojo:

```
proveedor nuevo : 408 caracteres
en vivo         : 408 caracteres
>>> IDENTICOS <<<
termina en IDAQAB: True
```

`IDAQAB` es el cierre de una llave pública RSA. Si termina en otra cosa, se truncó.

4. Verificar los cuatro registros críticos después, no asumirlos:

```
MX     smtp.google.com (pri 1)             OK
SPF    un solo registro, intacto           OK
DKIM   408 caracteres, termina en IDAQAB   OK
DMARC  p=quarantine                        OK
```

Cero interrupción de correo.

Convivir con un segundo proveedor

Después se añadió un servicio de envío transaccional para el formulario del sitio. Ahí aparece **el error que rompe el SPF de una empresa**:

> **Un dominio solo puede tener UN registro SPF.**

Si ya existe `v=spf1 include:_spf.google.com ~all` y se añade un segundo `v=spf1 include:otro-proveedor ~all`, **los servidores ven dos registros, no saben cuál aplicar, y fallan los dos**. Se pierde la autenticación entera por añadir un proveedor.

Dos salidas correctas:

- **Combinar en una sola línea**: `v=spf1 include:_spf.google.com include:otro ~all`
- **O que el proveedor use un subdominio delegado** (`send.dominio.com` por CNAME), con su propio SPF dentro. Entonces no hay conflicto porque no comparten nombre.

En este caso el proveedor usó la segunda. El resultado verificado:

```
TU CORREO                     PROVEEDOR NUEVO
MX    Google            OK    DKIM   selector propio   OK
SPF   un solo registro  OK    CNAME  send              OK
DKIM  selector google   OK    CNAME  rsend             OK
DMARC p=quarantine      OK
```

Dos sistemas de correo firmando por el mismo dominio, con selectores DKIM distintos y sin tocarse.

Lo que esto no cubre

- **DMARC no protege el nombre visible.** Un atacante puede poner *"Belona Cybersecurity"* como nombre para mostrar desde `gmail.com` y DMARC no dice nada: el dominio del "De:" es `gmail.com`, y ese sí está autenticado. Contra eso sirve la formación del personal, no el DNS.
- **No protege dominios parecidos.** `belonacyberr.com` es otro dominio y tiene su propio DMARC. Se vigila con monitoreo de registros similares.
- **`~all` (softfail) frente a `-all` (hardfail):** con DMARC en enforcement la diferencia pesa poco, pero `-all` es más explícito. Pendiente al pasar a `p=reject`.
- **BIMI** —que el logo aparezca junto al correo— exige DMARC en enforcement **más un certificado de marca verificada** que cuesta más de mil dólares anuales. Fuera de alcance por ahora.

Lo que un cliente recibe

1. Los tres registros configurados y **verificados desde dos resolvedores públicos independientes**, no solo desde el panel del proveedor.
2. El despliegue **por etapas**, con la fecha de la siguiente y el criterio para avanzar.
3. **El informe mensual en lenguaje claro**: quién intentó mandar correo a su nombre, qué pasó, y si algo legítimo suyo está fallando.
4. La documentación de qué se cambió y cómo revertirlo.

El punto 3 es el que cambia la conversación. **Sin el `rua=`, la empresa tiene una política y ninguna visibilidad.** Con él, cada mes sabe quién está intentando suplantarla — y eso convierte un trámite técnico en un control que se puede enseñar.

Caso del portafolio técnico de Belona Cybersecurity. Realizado sobre dominio propio; los valores mostrados son reales.
